> root@shiru:~$ execute_presentation.sh

FRAMEWORKS_DE_CIBERSEGURIDAD.exe

El Arsenal del Hacker // Navegando la Grid Digital

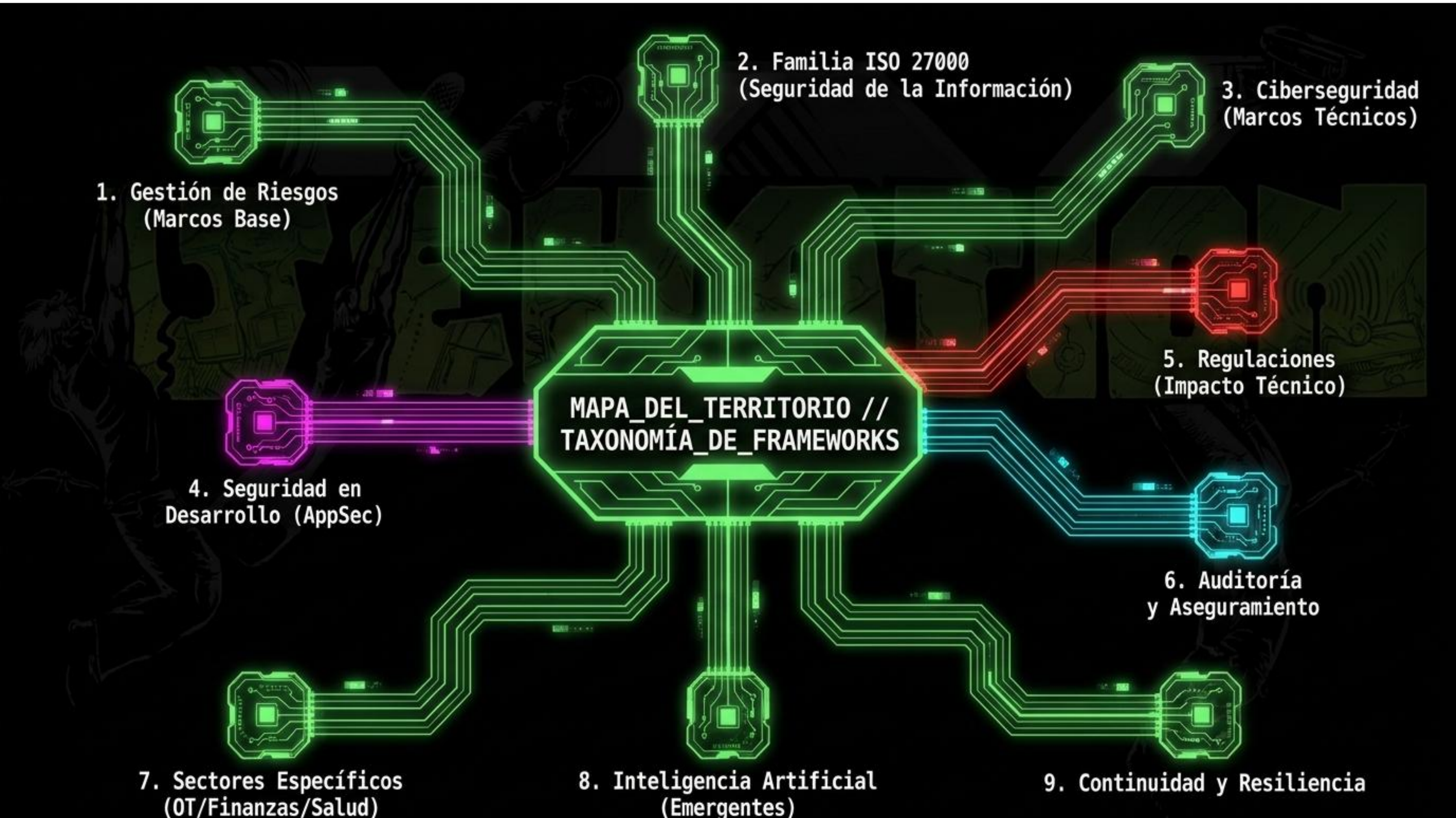
Autor: Fernando Contreras / Shiru

Estado: ACCESO_CONCEDIDO // REFERENCIA_TÉCNICA_COMUNIDAD

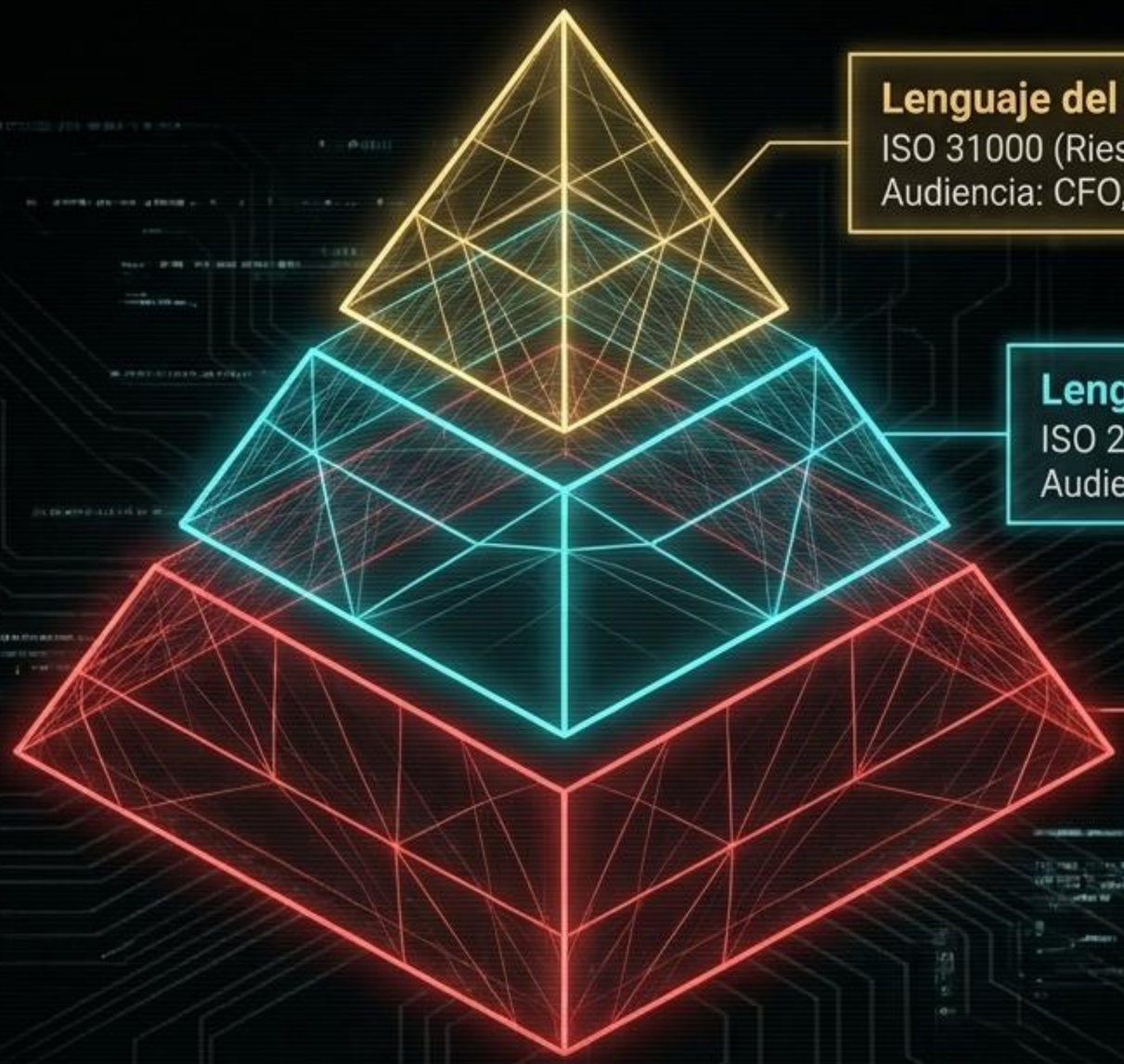
> cat /etc/filosofia.txt

Piensa como Atacante, Decide como Negocio.

Los frameworks no compiten entre sí; son un arsenal complementario. El objetivo no es implementar todos, sino saber qué arma táctica usar para conectar el elriesgo técnico (la visión del atacante) con la estrategia corporativa (la visión del directorio).


MAPA_DEL_TERRITORIO //
TAXONOMÍA_DE_FRAMEWORKS
1. Gestión de Riesgos
(Marcos Base)
2. Familia ISO 27000
(Seguridad de la Información)
3. Ciberseguridad
(Marcos Técnicos)
4. Seguridad en
Desarrollo (AppSec)
5. Regulaciones
(Impacto Técnico)
6. Auditoría
y Aseguramiento
7. Sectores Específicos
(OT/Finanzas/Salud)
8. Inteligencia Artificial
(Emergentes)
9. Continuidad y Resiliencia

> LA_TRÍADA_DE_COMUNICACIÓN // TRADUCCIÓN_DE_RIESGOS



Lenguaje del Dinero y el Negocio
ISO 31000 (Riesgo General) & FAIR (Cuantificación en USD)
Audiencia: CFO, Directorio

Lenguaje de Gestión y Procesos
ISO 27001 (SGSI) & NIST CSF 2.0 (Govern, Identify...)
Audiencia: CISO, Gerentes

Lenguaje Técnico y del Atacante
MITRE ATT&CK, CIS Controls, OWASP
Audiencia: SOC, Analistas, DevSecOps

```
> SELECT * FROM marcos_de_riesgo;
```

ISO 31000:2018	ISO 27005:2022	NIST RMF (SP 800-37)	FAIR
Qué es: El paraguas corporativo. Enfoque: Universal, conecta ciberseguridad con riesgo empresarial. No certificable.	Qué es: El proceso de InfoSec. Enfoque: Identificación → Análisis → Tratamiento. Requerido para 27001.	Qué es: Estándar federal EE.UU. Enfoque: 7 pasos, altamente prescriptivo (Categorize, Select, Implement...).	Qué es: Modelo cuantitativo. Enfoque: Responde ¿Cuánto nos costará?. Calcula pérdida probable en dinero.

> SISTEMA_OPERATIVO_CORPORATIVO // FAMILIA_ISO_27000

ISO 27001:2022
El SGSI

Estándar certificable. Da estructura, exige compromiso directivo y un proceso de riesgos.

ISO 27002:2022 (La Biblioteca)

- Organizativos (37)
- Personas (8)
- Físicos (14)
- Tecnológicos (34)

Nuevos controles 2022:
Threat Intel, Enmascaramiento de datos, Seguridad Cloud.

> ZONA_CLOUD // RESPONSABILIDAD_COMPARTIDA

CLIENTE	PROVEEDOR CLOUD (CSP)
ISO 27017:2015 Define controles responsabilidad del cliente (ej. gestión de acceso, configuración de aplicaciones).	**ISO 27017:2015** Define controles del CSP (ej. aislamiento de hipervisor, seguridad física del data center).

ISO 27018:2019 [PRIVACY ADD-ON]

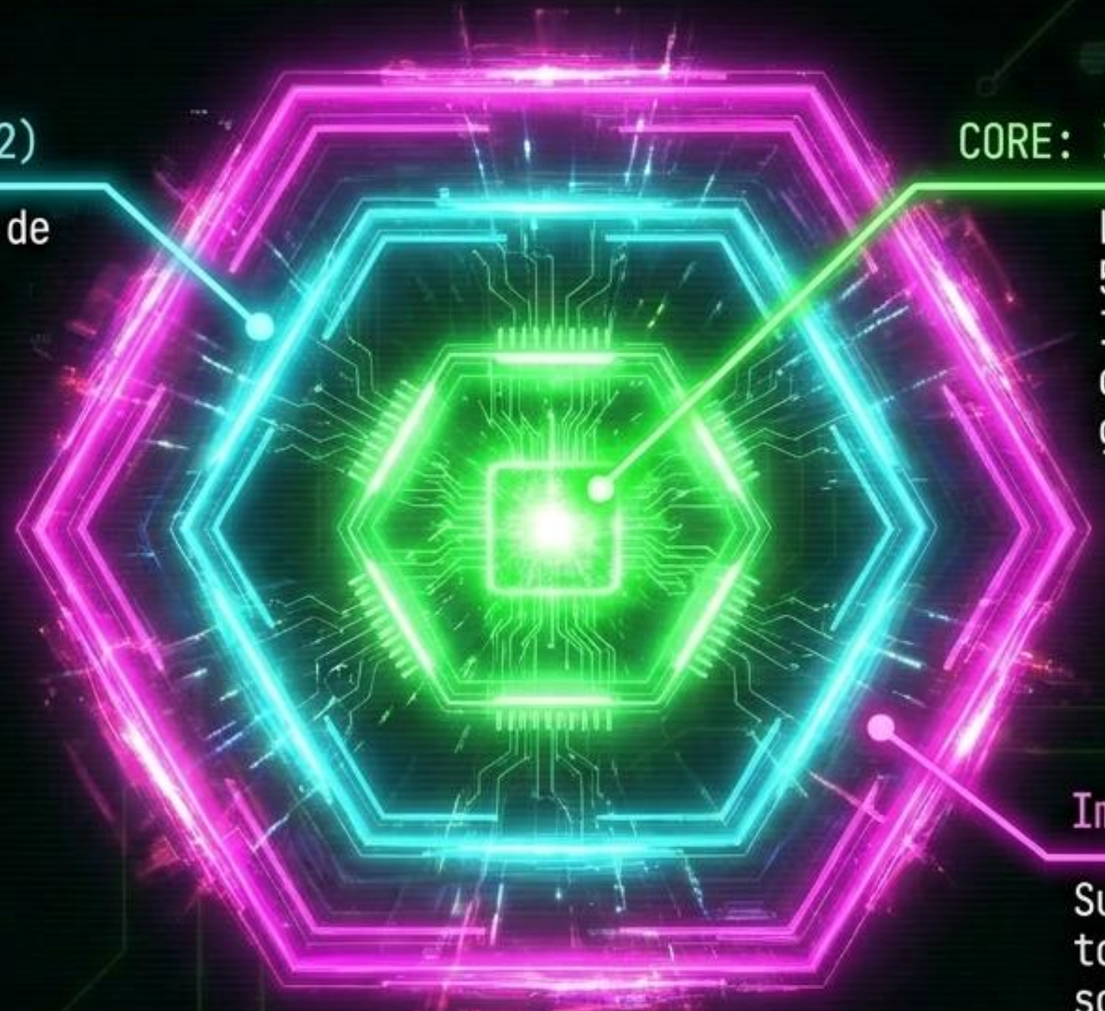
Puente entre InfoSec y Privacidad (PII). Exige al CSP: Consentimiento, Transparencia en subprocesadores y Notificación obligatoria de brechas de datos.

> PROTOCOLOS_DE_CRISIS_Y_PRIVACIDAD

Base para armar un CSIRT. (Nota: ISO 27032 maneja la colaboración/Threat Intel en el ciberespacio).

[ ] Extensión directa de ISO 27001 para privacidad (PII).
[ ] Controlador: Quién decide finalidad y uso.
[ ] Procesador: Quién opera bajo instrucción.

> DEFENSA_TÁCTICA_BASE // CIS_CONTROLS_V8



Implementation Group 2 (IG2)

Suma controles para defensa de red, respuesta a incidentes, pruebas de penetración.

CORE: Implementation Group 1 (IG1)

La higiene básica.
56 sub-controles obligatorios: Inventario HW/SW, protección de datos, configuración segura, gestión de vulnerabilidades.

Implementation Group 3 (IG3)

Suma hasta 153 sub-controles totales. Mapean directamente sobre la biblioteca ISO 27002 para organizaciones maduras.

Propósito táctico: Responde a 'Si tengo recursos limitados, ¿qué hago primero?'

> SIMULACIÓN_ADVERSARIA // MITRE_FRAMEWORKS

MITRE ATT&CK
(RED TEAM)

El comportamiento del adversario.

14 Tácticas
(El Por Qué - ej. Initial Access)

196+ Técnicas
(El Cómo - ej. Phishing T1566)

Permite construir casos de amenaza reales, no teóricos, basados en TTPs.

MITRE D3FEND
(BLUE TEAM)

El arsenal defensivo.

Mapea contramedidas técnicas directas contra las técnicas de ATT&CK.

Permite tomar decisiones de inversión basadas en simulaciones reales.

> ANATOMÍA_DE_UN_EXPLOIT // PIPELINE_DE_VULNERABILIDAD

PASO 1: CAPEC

Patrón de Ataque

- Cómo ataca el adversario. (Ej: Inyección de datos).

PASO 2: CWE

Debilidad Raíz

- El defecto de software subyacente. (Ej: CWE-89 SQL Injection).

PASO 3: CVE / NVD

El Bug Específico

- La instancia real en un producto. Identificador único universal. (Ej: CVE-2021-44228 Log4Shell).

PASO 4: CVSS v3.1/v4.0

Severidad (Score 0-10)

ALERTA DEL SISTEMA: CVSS indica severidad técnica externa, NO es igual a Riesgo Interno. Debe calcularse el Environmental Score.

> scan_appsec_targets // OWASP_TOP_10_COMPARISON

OWASP Web (2021)

- Broken Access Control (A01)
- Cryptographic Failures
- Injection (A03)
- Componentes vulnerables

OWASP API (2023)

- BOLA / IDOR (API1)
- Broken Authentication
- Lógica de negocio de datos
- Consumo de recursos sin restricción

EVOLUTION OF THREAT VECTOR

OWASP LLM/IA (2025)

- Prompt Injection (LLM01)
- Envenenamiento de datos de entrenamiento
- Disclosure de info sensible
- Excessive Agency (IA autónoma)

> MADUREZ_DEVSECOPS // ASEGURAMIENTO_DE_CÓDIGO

OWASP SAMM

Framework prescriptivo. 15 prácticas en 5 funciones. Escala 0-3 (Ausente a Optimizado).

BSIMM

Framework descriptivo. Basado en datos reales de 130+ empresas. Compara tu programa contra el benchmark del mercado (¿Qué hace el resto?).

OWASP ASVS

Estándar de verificación técnica. Define requisitos estrictos para pruebas de aplicaciones críticas.

NotebookLM

> ZONAS_DE_PELIGRO_LEGAL // RIESGO_REGULATORIO

> CRIPTOGRAFÍA_DE_CONFIANZA // AUDITORÍA_SOC

SELLO: SOC 1

Enfoque: Reporte Financiero.
Demuestra que tus fallos de seguridad o procesos no arruinarán la contabilidad del cliente.

SELLO: SOC 2

El estándar de oro Enterprise B2B.
Evalúa 5 Criterios (TSC): Seguridad (Obligatorio), Disponibilidad, Integridad, Confidencialidad, Privacidad.
Tipo I: Foto de un instante (Diseño).
Tipo II: Película de 6-12 meses (Efectividad).

SELLO: SOC 3

Versión resumida y pública.
Para marketing y sitios web, sin detalles técnicos sensibles expuestos.

> ICE_ESPECÍFICO_POR_SECTOR // CONTRAMEDIDAS_INDUSTRIALES

IEC 62443 (Sistemas Industriales / OT)

- Riesgo físico (vidas, medio ambiente).
- Modelo de zonas y conductos.
- Niveles SL0 a SL4.
- No se puede parchear fácilmente.

NERC CIP

Obligatorio para infraestructura eléctrica crítica (generación y transmisión) en Norteamérica.

TISAX

Estándar de la industria automotriz europea. Niveles de etiqueta (1-3) para evitar auditorías redundantes en la cadena de suministro.

SWIFT CSCF

Controles obligatorios para infraestructura bancaria global. Respuesta a robos millonarios a bancos centrales.

> CONTENCIÓN_SINTÉTICA // MARCOS_DE_INTELIGENCIA_ARTIFICIAL

ISO 42001:2023 (SGAI)

El primer estándar certificable. 33 controles. Exige explicabilidad, supervisión humana y evaluación de sesgos.

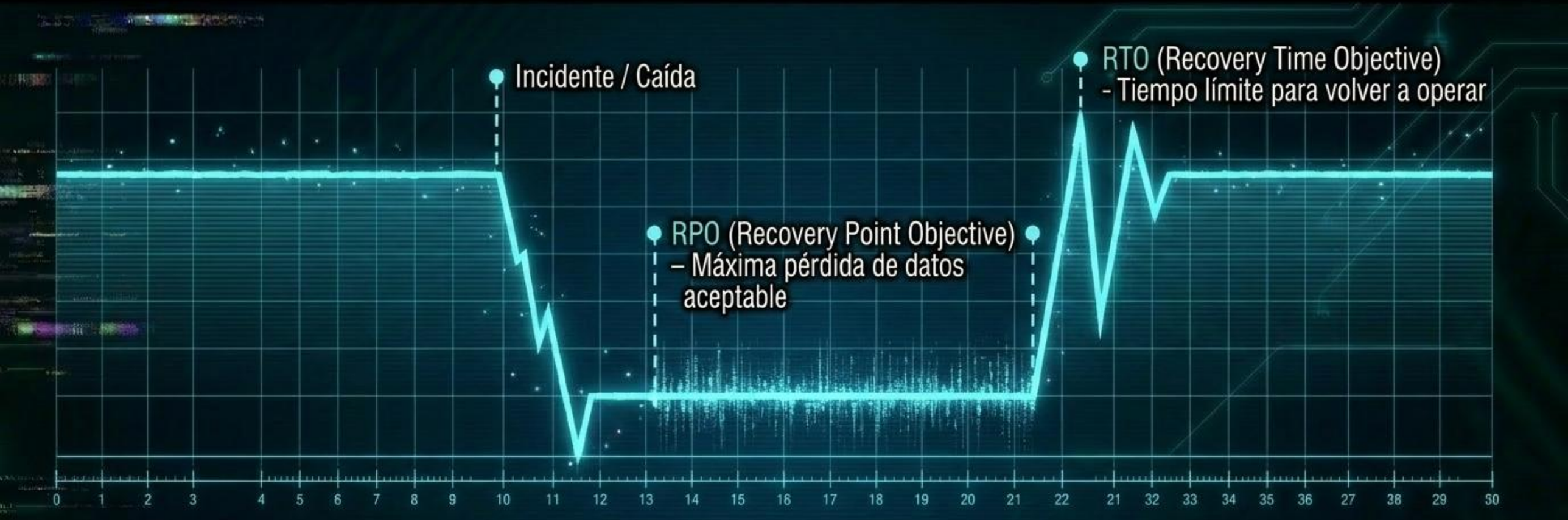
EU AI Act (Regulación por Riesgo)

- [Rojo] Inaceptable: Prohibido (ej. puntuación social).
- [Naranja] Alto Riesgo: DPIA requerido, infraestructura crítica.
- [Amarillo] Riesgo Limitado: Transparencia/Chatbots.
- [Verde] Riesgo Mínimo.

EL RADAR: NIST AI RMF

4 funciones para gestionar IA: GOVERN, MAP, MEASURE, MANAGE.

> RESILIENCIA_DEL_SISTEMA // CONTINUIDAD_DE_NEGOCIO



ISO 22301:2019 (SGCN)

Estándar certificable para operar durante y después de interrupciones graves.

ISO 22317 (BIA - Business Impact Analysis)

El diagnóstico fundamental. Define la Disponibilidad cuantificando el impacto del tiempo de inactividad.

> execute_synthesis // CÓMO_ELEGIR_EL_FRAMEWORK_CORRECTO

```
IF [Iniciando_Programa_De_Seguridad]
    THEN Deploy -> [ISO 27001] + [CIS Controls v8 (IG1)] + [ISO 27005]

IF [Evaluando_Aplicaciones_Web]
    THEN Deploy -> [ISO 27005] + [OWASP Top 10] + [CWE Top 25] + [CVSS]

IF [Protegiendo_Entornos_Industriales]
    THEN Deploy -> [IEC 62443] + [MITRE ATT&CK ICS]

IF [Procesando_Datos_En_Nube_PII]
    THEN Deploy -> [ISO 27701] + [GDPR/Local] + [ISO 27018]

IF [Exigencia_Comercial_B2B_Enterprise]
    THEN Deploy -> [SOC 2 Tipo II]

IF [Implementando_Inteligencia_Artificial]
    THEN Deploy -> [ISO 42001] + [OWASP LLM Top 10] + [EU AI Act]

IF [Presentando_Al_Directorio]
    THEN Deploy -> [NIST CSF 2.0] + [ISO 31000] + [FAIR]
```

```
> system_shutdown
```

Ningún framework por sí solo resuelve el problema de la gestión de riesgos. Lo que resuelve el problema es entender el contexto, elegir las herramientas adecuadas, y tener el criterio para aplicarlas con sentido.

— Fernando Contreras / Shiru // SYS.OFFLINE